ASSIGNMENT-05

Name :- Mangla Patidar

Enrollment no. :- 23CSA3BCA1044

Q1. The Architecture of a Security Policy

Question:

A mid-sized company is drafting its first set of official security documents. They need to distinguish between high-level intent and specific rules for web and email usage.

- Explain three core reasons why a formal Security Policy must be developed rather than relying on informal "best practices."
- Draft three specific "Do's and Don'ts" that should be included in a standard Email Security Policy to prevent data leakage and phishing.

Answer:

(a) Need for a Formal Security Policy

A formal Security Policy is essential for the following reasons:

1. **Clarity and Consistency:**
   It provides clear rules and guidelines for all employees, ensuring consistent security practices across the organization.
2. **Legal and Compliance Requirements:**
   A written policy helps organizations meet legal, regulatory, and audit requirements.
3. **Accountability and Enforcement:**
   It defines responsibilities and consequences, making it easier to enforce security measures and take action in case of violations.

(b) Email Security Policy: Do's and Don'ts

Do's:

1. Use strong passwords and enable two-factor authentication for email accounts.
2. Verify sender identity before opening attachments or clicking links.
3. Report suspicious emails (phishing attempts) to the IT/security team immediately.

Don'ts:

1. Do not share sensitive information (passwords, financial data) via email.
2. Do not open unknown attachments or click on suspicious links.
3. Do not use official email for personal or untrusted communications.

Q2. Global Standards: The Role of ISO

Question:

An Indian software firm wants to bid for a government contract in the European Union. The contract requires the firm to be ISO 27001 certified.

- What is the primary focus of ISO 27001 in the context of an Information Security Management System (ISMS)?
- How does adhering to an international standard like ISO improve a company's security posture beyond local laws?

Answer:

(a) ISO 27001 Definition

ISO 27001 is an international standard that defines the requirements for establishing, implementing, maintaining, and improving an **Information Security Management System (ISMS)**.

Its primary focus is to ensure the **confidentiality, integrity, and availability** of information through a risk management process.

(b) Strategic Benefits of ISO Standards

1. **Global Recognition and Trust:**
   Certification builds trust with international clients and partners.
2. **Standardized Security Practices:**
   It ensures the company follows globally accepted best practices, not just local regulations.
3. **Improved Risk Management:**
   Helps identify, assess, and mitigate risks proactively.
4. **Competitive Advantage:**
   Increases eligibility for global contracts and business opportunities.

Q3. Protecting the "Idea": IPR, Patents, and Copyright

Question:

A developer creates a unique algorithm for a new social media platform and writes the entire source code from scratch.

- Differentiate between Copyright Act protection and Patent Law. Which protects the code and which protects the idea/process?
- Why is Intellectual Property Rights (IPR) considered a "double-edged sword" for innovation?

Answer:

(a) Copyright vs Patent Law

- **Copyright:**
  Protects the **actual written source code** (expression of the idea).
  It prevents others from copying or reproducing the code.
- **Patent Law:**
  Protects the **functional idea, algorithm, or process** behind the software.
  It prevents others from using the same concept without permission.

(b) IPR as a Double-Edged Sword

IPR is called a double-edged sword because:

- **Positive Side:**
  - Encourages innovation by protecting creators' rights
  - Provides financial rewards and recognition
- **Negative Side:**
  - Can restrict innovation if ideas are overly protected
  - May lead to monopolies and limit competition

Q4. Legal Compliance and the IT Act

Question:

A company updates its privacy policy but fails to notify its users. Later, a data breach occurs and the company is sued under the Indian IT Act.

- Explain the Publishing and Notification Requirement of policies. Why is a policy legally "invisible" if not communicated?
- Mention two key provisions of the Indian IT Act related to liability for failing to protect sensitive personal data.

Answer:

(a) Publishing and Notification Requirement

Security policies must be **properly published and communicated** to employees and stakeholders.

- Employees must be aware of rules and responsibilities
- Users must be informed about how their data is handled

Why it becomes "legally invisible":
If a policy is not communicated, it cannot be enforced because people cannot follow rules they are unaware of. In legal terms, it has no practical validity.

(b) Key Provisions of the Indian IT Act

1. **Section 43A:**
   Provides compensation for failure to protect sensitive personal data due to negligence.
2. **Section 72A:**
   Punishes unauthorized disclosure of personal information with imprisonment or fines.